

第5章：系统概要设计— 4.高可信软件体系结构

• 学习目的和要求

- 可依赖性系统的概念—**掌握**
- 容错体系结构—**理解**
- 信息安全概念和技术—**掌握**
- 信息安全体系结构—**理解**



一、可依赖系统

1.可依赖性的概念

随着计算机系统已深入到我们的业务和生活中，系统与软件的失效所带来的问题也在增加。一个电子商务公司的服务软件的失效有可能导致收入上的较大损失；一个嵌入汽车上的软件发生错误可能会导致昂贵的召回和维修费用，甚至成为导致意外事故的因素之一。

可依赖性 (dependability) 这个概念是由Jean-Claude Laprie在1995年提出来的，目的是覆盖系统的可用性、可靠性、安全性和信息安全性。

一个有用的系统并不一定总是具有很高的可依赖性。如office，所以我们经常保存文件并额外进行一些备份。

关键性系统：某些系统属于关键性系统类别，其系统故障可能导致人身伤害、破坏环境或巨大的经济损失。如医疗中的嵌入式设备，如胰岛素泵（安全关键）、航天器导航系统（关键任务）和在线转账系统（关键业务）。

一、可依赖系统

2. 可依赖性属性

计算机系统的可依赖性是用来衡量其可信赖度的性能指标，包含5个维度。



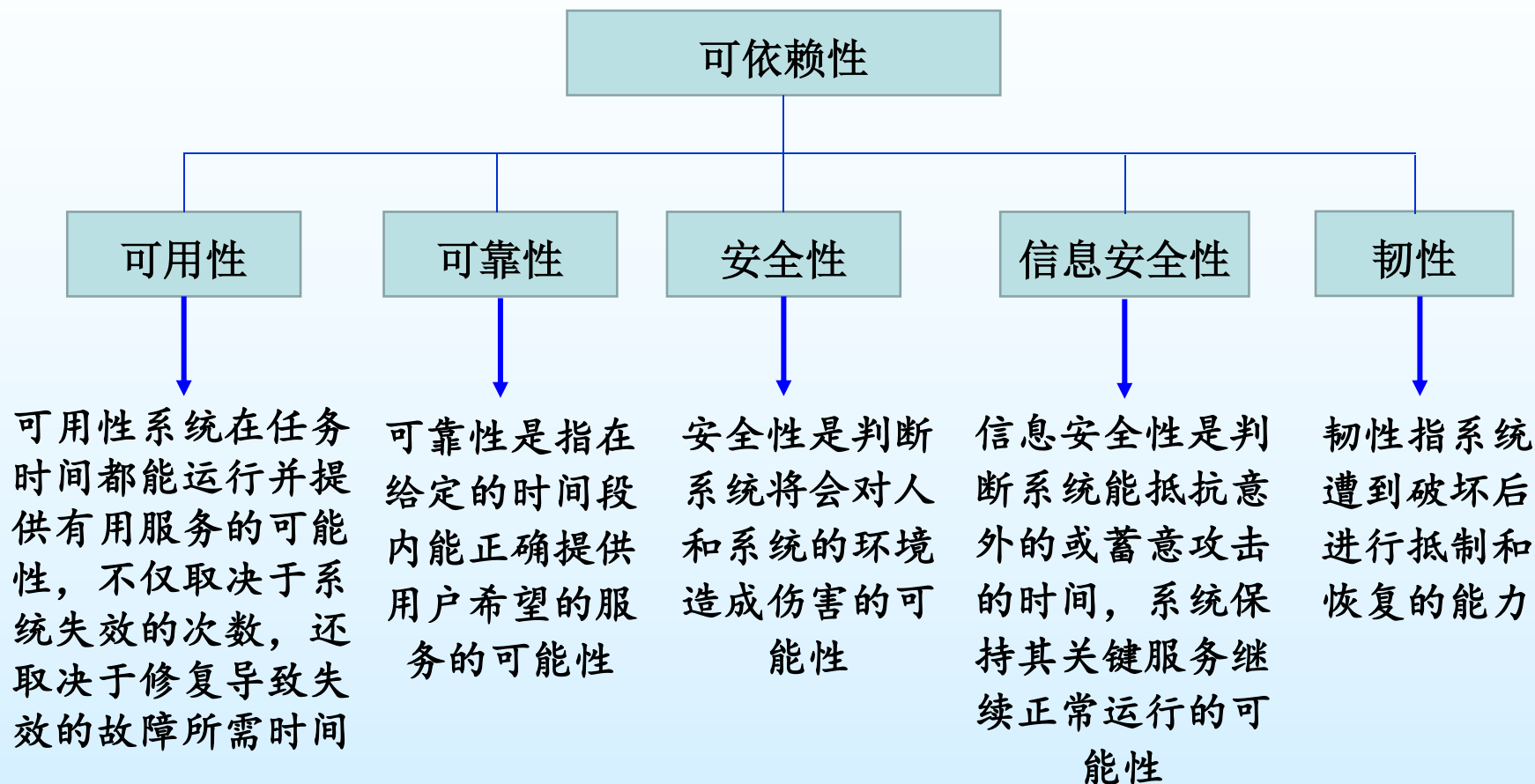
例如：系统A每一年失效一次，系统B每个月失效一次，**则系统A比系统B相对更可靠**。然而，如果系统A需要花6个小时才能重新启动，而系统B只需5分钟就可以重新启动，**那么会认为B系统全年而言比A系统更具有可用性**。

电话交换机系统是一个可用性比可靠性更重要的例子。当拿起听筒时，用户希望听到拨号音，因此系统具有较高的可用性需求。即使一次连接建立起来以后系统发生了故障，故障也可以快速恢复，即交换机通常可以重置系统并重新连接。这可能发生的非常之快，以至于用户可能察觉不到。

一、可依赖系统

2. 可依赖性属性

计算机系统的可依赖性衡量其可信赖度的性能指标，包含5个维度。



一、可依赖系统

2. 可依赖性属性

1993年9月，一架飞机在风暴中降落波兰华沙机场。开始降落后的**9秒**时间里，飞机计算机制动系统突然失灵。制动系统并未检测出飞机已经着陆并认为飞机还在空中。飞机的安全特性中止了逆推力系统的工作，因为逆推力系统可以降低飞机的速度，它在空中启动是危险的。飞机脱离跑到向外冲去，撞上了泥土堤岸，引起大火。

对于事故的调查显示，制动系统软件按其规格说明正常工作了，程序中是没有错误的。然而，软件需求规格说明是不完备的，它没有考虑到一些特殊的情况，使得软件正常工作但系统失效了。

可依赖性需求分为**2种**：

- **功能性需求**：定义了系统应包含的检查和修复措施，以及防止系统失效和外部攻击的保护错误。
- **非功能性需求**：定义了系统需要的可靠性和可用性。

一、可依赖系统

3. 可依赖性度量

可依赖性可以被描述为系统在一个指定的运行环境中使用时发生失效的概率。以下这些度量可以用来刻画可依赖性。

1.请求失效概率(Probability of Failure On Demand,POFOD)。

这个度量定义系统服务请求将导致失效的可能性。 $POFOD=0.001$ 意味着当提出一个请求的时候可能发生失效的概率为 $1/1000$ 。

2.失效发生率(Rate of Occurrence of Failure,ROCOF)。这个度量说明在一段时间（比如1小时），或在一定的系统执行次数之内，能观测到系统失效的次数。例如，在1000次事务处理中有1次是失效的， $ROCOF= 1/1000$ 。 $ROCOF$ 的倒数是平均失效间隔时间(MTTF)， $ROCOF$ 为每小时2次失效，意味着平均失效时间为30分钟。

3.可用性(AVAIL)。说明当请求某一服务的时间内系统可使用的概率。例如， $AVAIL=0.9999$ 说明平均来说系统在运行时间99.99%是可用的。

二、提高系统可依赖性策略

1. 冗余和多样性

实现和提高可依赖性的策略依赖于冗余和多样性。冗余性意味着系统中包含多余的能力，可以在系统失效时发挥作用。多样性意味着冗余的系统构件是属于不同类型的，这样它们就很难以完全一样的方式失效。

在可用性要求高的系统中，冗余的服务常常被使用。这些服务在指定的服务失效时自动运行。有时候，为保证攻击不能够暴露一个常见弱点，这些服务可能属于不同的类型并且可能在不同的操作系统上运行。

阿丽亚娜5型火箭爆炸

1996年，欧洲航天局的阿丽亚娜5型火箭在其首次飞行开始37秒后发生爆炸。事件是由于软件系统失效造成的。火箭上有个软件备份系统，但这个系统并不具有多样性，所以备份计算机也以同样的方式失效了。火箭和卫星的有效载荷全部被摧毁。

二、提高系统可依赖性策略

2. 故障避免技术

错误、故障和失效之间的差别，帮助我们找出3个可用于改善系统可靠性的辅助方法：

1.故障避免。在系统设计和实现过程中使用一些软件开发方法来减少编程故障发生，并且在系统投入使用前发现系统中的故障。**故障避免技术包括：**使用强类型的程序设计语言以允许全面的编译器检查和尽量不要使用容易出错的程序设计语言元素（如指针）。

强类型语言：是一种强制类型定义的语言，即一旦某一个变量被定义类型，如果不经强制转换，那么它永远就是该数据类型。强类型语言包括：Java、.net、Python、C++等语言。

弱类型语言：是一种弱类型定义的语言，某一个变量被定义类型，该变量可以根据环境变化自动进行转换，不需要经过现行强制转换。弱类型语言包括：VB，PHP，JavaScript等语言。

二、提高系统可依赖性策略

2. 故障避免技术

2.故障检测和修复。在部署之前进行验证和确认来发现和去除程序中的故障。关键性的系统需要广泛的验证和确认过程，以便在部署之前发现尽可能多的故障。系统的测试和调试以及静态分析时故障检测技术的实例。

3.容错。系统应该设计成为具备容错能力的，即系统的故障及无法预期的系统行为在执行时能够得到检测和管理，避免系统失效。**在所有系统中都应该包含一种基于内嵌的运行时检测的容错方法。**

应用故障避免、故障检测和容错技术并非总是成本-效益合算的，发现和清除系统中残余故障的成本呈指数级增加。当软件越来越可靠时，用来查找故障所消耗的时间和精力越来越多。因此，软件开发企业默认他们的软件存在一些残余故障，允许的故障水平依赖于系统类型。

三、容错体系结构

容错机制是一种确保运行时可靠性的方法，它定义了系统发生错误后的运行机制，即使发生软件或硬件故障，也能保证系统正常工作。容错机制可以检测并纠正错误状态，使故障的发生不会导致系统失效。

为了提供容错机制，系统体系结构必须具有一定的冗余性，以及多样化的硬件和软件。例如：飞行器系统就需要容错体系结构，以确保通信系统、关键命令和控制系统在飞行过程中始终可用。

容错设计

- 硬件容错：对关键硬件部件进行备份
- 软件容错：备份软件逻辑和数据

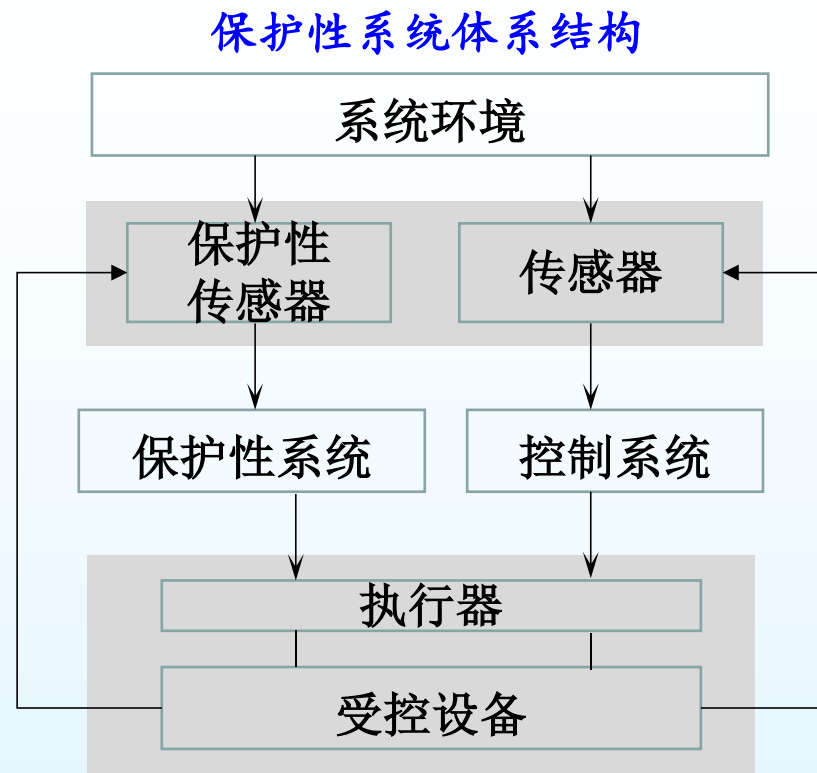
常见的3类不同类型的容错体系结构包括：保护系统、自监控系统体系结构和N版本编程。

三、容错体系结构

1. 保护性系统

保护性系统是一种与其他系统相关的专用系统。它通常是对一些过程的控制系统，比如化学制造过程或一个设备控制系统。保护性系统的例子可能是一个火车上探测火车是否正在通过一个红色信号灯的系統。如果是，并且没有迹象显示火车控制系统正在减速，那么保护性系统会要求系统制动使其停止。

保护性系统独立地监视系统环境，如果传感器指示控制系统没有正常工作，那么保护系统被激活并且指挥设备运行。保护性系统只包含最紧要的功能，能把系统从危险状态转换到安全状态，因此可投入更多的精力到保护系统的容错和故障检测上。

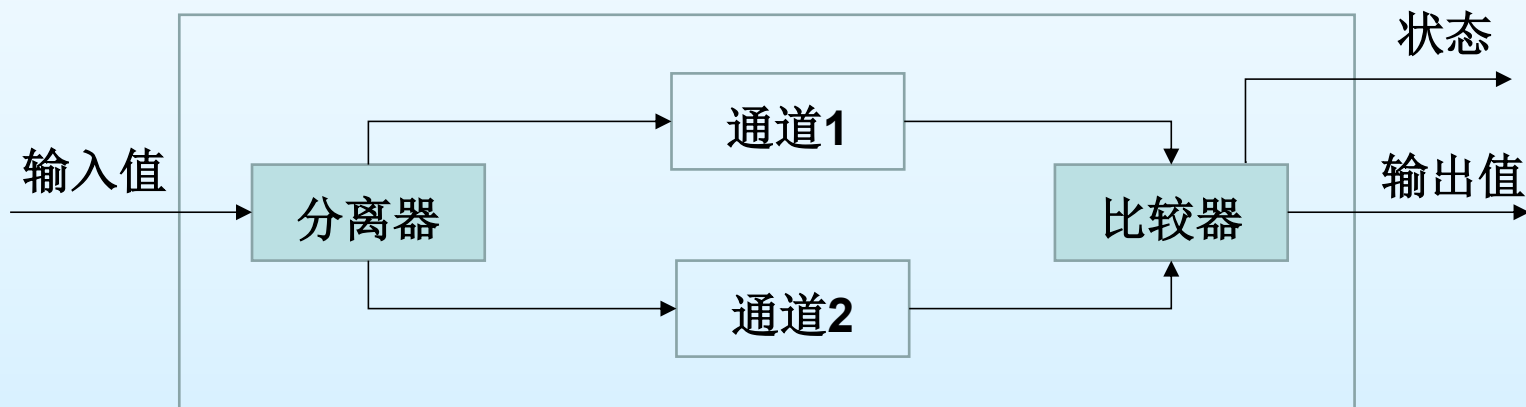


三、容错体系结构

2. 自监控体系结构

自监控体系结构是将系统设计成监视自身的操作，并在探测到问题时采取某些行动，这是通过在不同的通道计算并比较计算的输出来实现的，如果输出是一致的并且同时可用，那么可以判定系统运行是正常的；如果输出不同，那么可以假设发生了失效。当其发生的时候，系统通常会在状态输出线上输出一个失效异常，这会使控制被转移到另一个系统上进行。

自监控系统体系结构



三、容错体系结构

2. 自监控体系结构

为了能有效地检查硬件和软件故障，自监控系统必须被设计成：

1. 每一个通道上使用的硬件都是不一样的。现实中，这可能意味着每一个通道使用不同的处理器类型来实现要求的计算，或者是组成系统的芯片集可能源自不同的生产商。这降低了通常处理器设计故障影响计算的可能性。

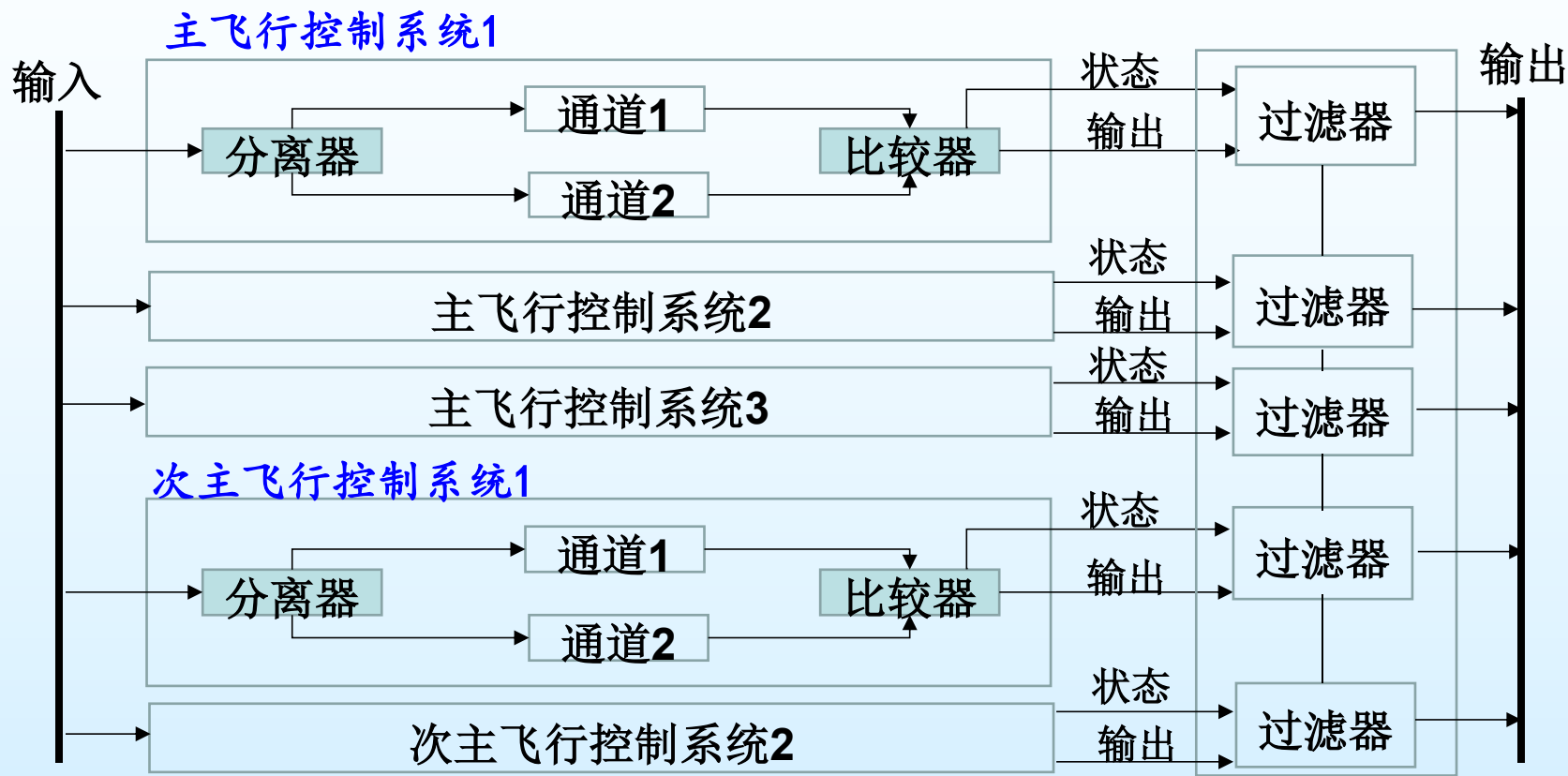
2. 在不同的通道上使用不同的软件。否则相同的软件错误可能会在同一时间在每一个通道上发生。

此体系结构可用于如下情形：计算的正确性非常重要，但可用性并不是很重要。对医疗和诊断系统，可靠性比可用性更加重要，因为错误的系统影响会导致病人接收错误的治疗。

三、容错体系结构

2. 自监控体系结构

在需要高可用的情况下，需要并行使用几个自监控系统，需要一个切换单元来检查故障，并在有两个通道产生一致结果时从一个系统取得结果。



空中客车飞行控制系统体系结构

三、容错体系结构

2. 自监控体系结构

系统中使用了**5**个自检查计算机并行地计算，使用的是同一个输入，输出被连接到一个硬件过滤器上以检测这个状态是否指示的是一个故障。

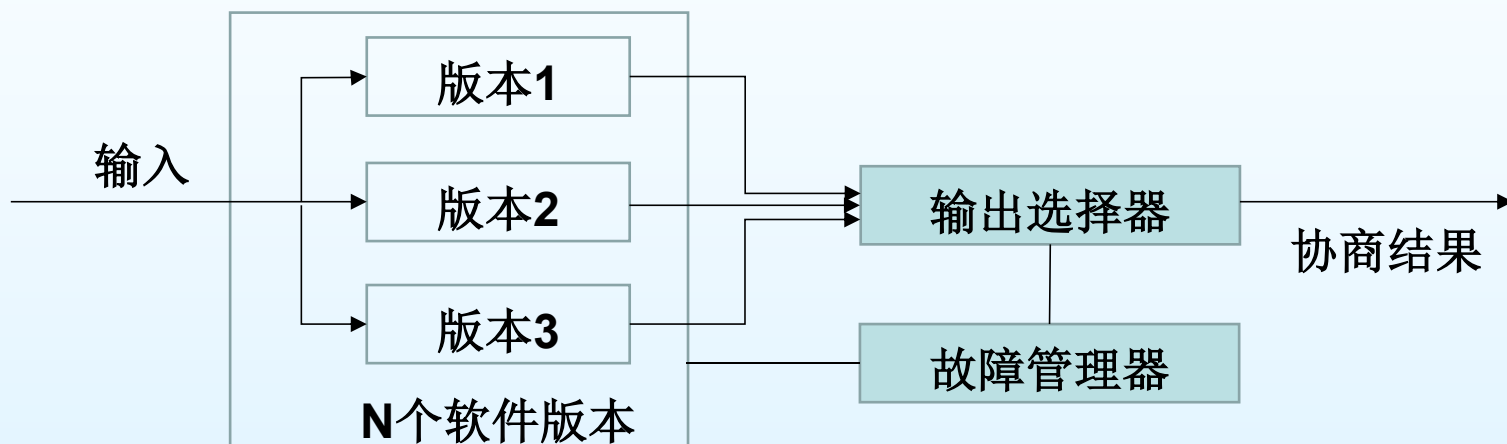
空中客车系统设计者尝试采用多种方法来获得多样性：

1. 主飞行控制计算机使用与次飞行计算机不同的处理器；
2. 主系统和次系统的每一个通道中使用的芯片组来自不同的生产商；
3. 次飞行控制系统中的软件只提供最紧要的功能，因此比主控制软件简单；
4. 主系统和次系统的每一个通道的软件使用不同的程序语言来开发，并且使用不同的开发团队。

三、容错体系结构

3. N版本编程

使用相同的规格说明，同一个软件由多个小组实现，这些版本在不同的计算机上执行，使用一个投票系统来比较它们的输出，不一致的输出或者未能及时产生的输出被拒绝。至少系统的3个版本是可用的，所以在发生单个失效的情况下，两个版本应该是一致的。



N版本编程

通过对实验分析，Hatton(1997)总结得出：一个三通道系统大约比单通道系统的可靠性高5-9倍，他认为，试图通过对单个版本投入更多资源以增进可靠性是达不到目的的，N版本更有可能产生可靠的系统。

四、信息安全工程

1. 信息安全概述

20世纪90年代互联网的广泛使用给软件工程师带来了新的挑战，即需要设计和实现能保证信息安全的系统。随着各种各样的外部攻击被人为地设计，严重威胁着系统的安全。攻击者可能会滥用系统硬件、盗窃机密数据或者是破坏系统所提供的正常服务。

在信息安全系统工程中，必须考虑以下3个信息安全的维度：

1.机密性。系统中机密的信息可能被泄露，被未获授权的人或程序访问到。例如：从电子商务系统窃取信用卡数据是一个机密性问题。

2.完整性。系统中的完整性信息可能被损坏或引起错误，使其异常或不可靠。例如：在系统中删除数据的蠕虫是一个完整性问题。

3.可用性。系统或数据有时可能会无法访问。例如：使服务器过载的拒绝服务攻击是系统可用性受到破坏的例子。

四、信息安全工程

1. 信息安全概述

从组织的角度来看，信息安全必须考虑3个层次：

1.基础设施信息安全。涉及所有系统和网络的信息安全维护，它们为组织提供基础设施和一套共享服务。

2.应用信息安全。涉及个人应用系统或相关系统群的信息安全。

3.操作信息安全。与组织的系统的安全运行和使用有关。

应用
可复用的构件和库
中间件
数据库管理
通用的共享应用（浏览器、电子邮件系统等）
操作系统
网络 计算机硬件

信息安全可能涉及的系统层级

四、信息安全工程

1. 信息安全概述

基础设施信息安全主要是一个系统管理问题，系统管理员配置基础设施以抵御攻击。系统信息安全管理包括用户和权限管理、系统软件部署和维护，以及攻击监控、检测和恢复等。

1.用户和权限管理。包括向系统添加和删除用户，确保系统在需要的地方采用了适当的用户认证机制，设置系统的权限让用户只能访问到他们应该访问的那些资源。

2.系统软件部署和维护。包括系统软件和中间件的安装，对这些系统进行正确的配置以保证安全漏洞不会出现；也包括不断地用新版本或补丁更新系统，及时修补发现的安全问题。

3.攻击监控、检测和恢复。包括对未授权的系统访问的监控、检测攻击和抵御攻击策略落实到位，以备份程序和数据以保证系统能在遭受到外部攻击后能恢复正常运行。

四、信息安全工程

1. 信息安全概述

信息安全术语—以医疗就诊系统为例

术语	定义
资产	必须保护的某种有价值的东西。资产可以是软件系统本身或者系统使用的数据——每位将接受或已接受治疗病人的记录
攻击	利用系统的漏洞，攻击者有目的地对系统资产或者财物造成损坏。攻击可能是外部攻击，也可能是内部攻击——扮演已授权用户
控制	一种减少系统漏洞的保护措施。加密是一个控制的例子，减少了弱访问控制系统的漏洞——密码校验系统，不允许用户密码时常见的名字或字典里常见的单词
暴露	可能对计算机系统造成的损失或损坏。这可能是针对数据的损失或损坏，也可能是当信息安全漏洞必须修复时花费的时间和工作量——病人信息泄露
威胁	有可能（潜在）造成损失或损坏的情况。可以把威胁看成一个受到攻击的系统漏洞——一名未授权的用户通过猜测另一名授权用户的凭证来获得访问权限
漏洞	基于计算机的系统弱点，可能利用漏洞造成损失或损坏——身份认证是基于不要求强口令的密码系统，用户可以设置很容易被猜到的密码

四、信息安全工程

2. 信息安全需求

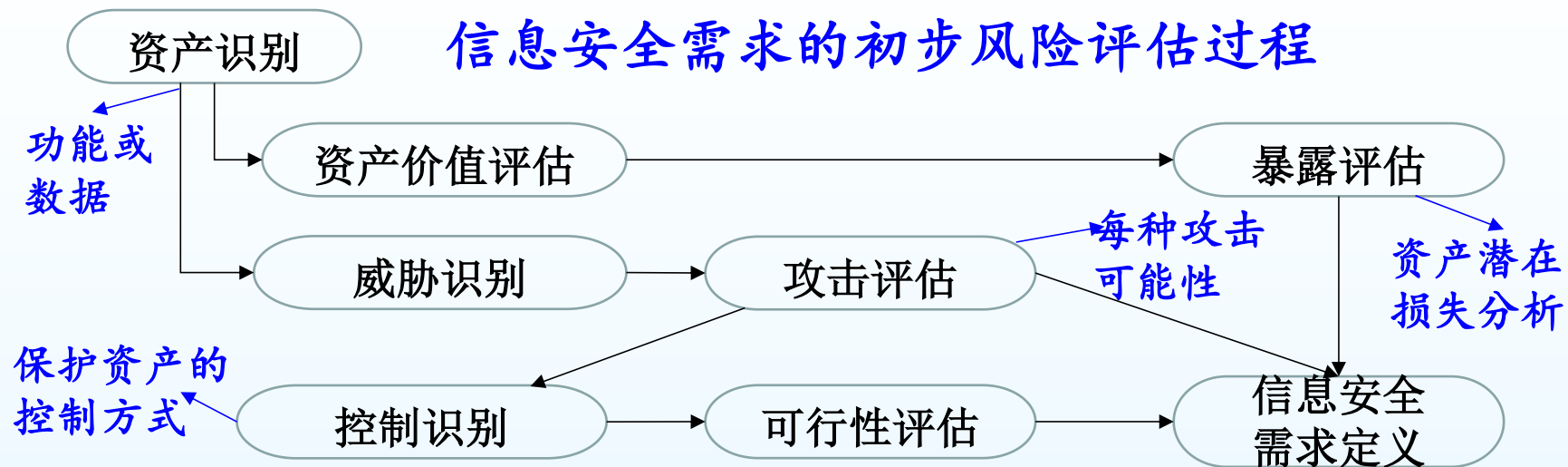
信息安全性是一个反应系统保护自己免受内外部攻击的系统属性。

Firesmith（2003）找出了在系统规格说明中**10类**信息安全需求：

1. **身份验证需求**定义系统是否应该在用户与之交互之前辨认其身份；
2. **认证需求**定义系统如何验证用户身份；
3. **授权需求**定义合法用户的权力和访问许可；
4. **免疫需求**定义系统如何保护自己免受病毒、蠕虫以及类似威胁入侵；
5. **完整性需求**定义如何避免数据损坏；
6. **入侵保护需求**定义在系统中应如使用什么机制来检测对系统的攻击；
7. **不可抵赖性需求**定义参与交互的乙方不能对自己做出的交易抵赖；
8. **隐私需求**定义如何维护数据的私密性；
9. **信息安全的审计需求**定义如何对系统的使用进行审计和检查；
10. **系统维护的信息安全需求**定义应用如何避免因信息安全机制的意外失效所导致的授权的修改。

四、信息安全工程

2. 信息安全需求



四、信息安全工程

2. 信息安全需求

资产识别

信息安全需求的初步风险评估过程

资产	价值	暴露
信息系统	高。要求支持所有临床咨询。潜在安全关键	高。财务损失，因为诊所可能会被注销营业执照。恢复系统的成本。病人得不到及时治疗的伤害
病人数据库	高。要求支持所有临床咨询。潜在安全关键	高。财务损失，因为诊所可能会被注销营业执照。恢复系统的成本。病人得不到及时治疗的伤害
单条病人记录	通常低，虽然对特定的身份显赫的病人可能是高	直接损失低但可能影响声誉

威胁	可能性	控制	可行性
未经授权的用户以系统管理员身份获取访问权限，使得系统不可用	低	只允许从物理上安全的地方进行系统管理	实现成本低，但必须小心密钥的分发，并确保在紧急情况下能得到密钥
未经授权的用户以系统用户的身份访问系统，获得机密信息	高	要求所有的用户使用生物机制进行身份验证，记录所有对病人信息的更改以及跟踪系统使用情况	技术可行但解决方案成本高，可能用户会抵触简单并且对实现透明，也支持恢复

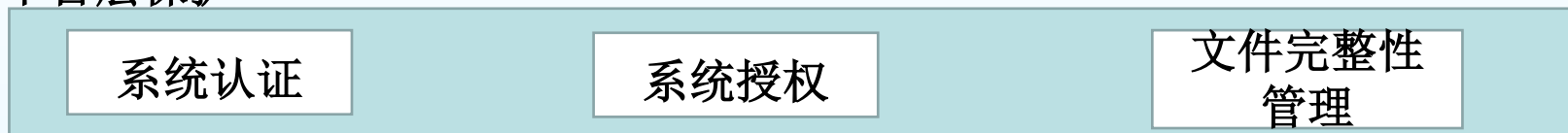
四、信息安全工程

3. 信息安全体系结构

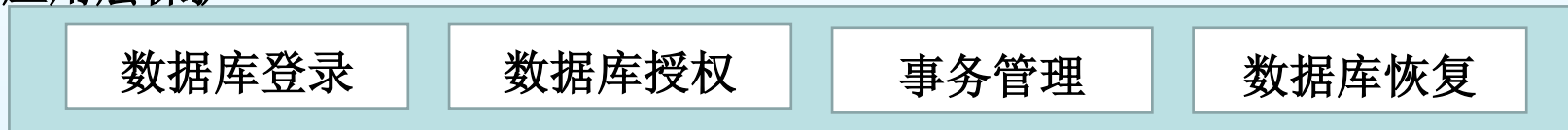
设计能维护信息安全性的系统体系结构时，需考虑两个基本问题：

1. 保护—如何组织系统使其关键资产能在外部攻击时得到保护？
2. 分布—如何对系统资产进行分布使得逞的攻击数减到最少？

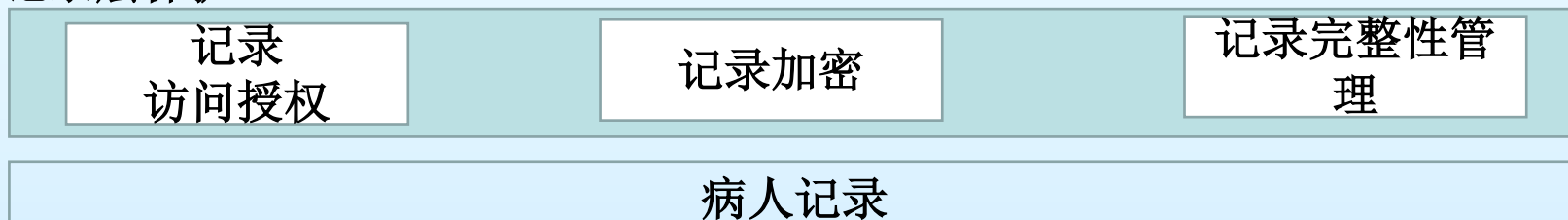
平台层保护



应用层保护



记录层保护

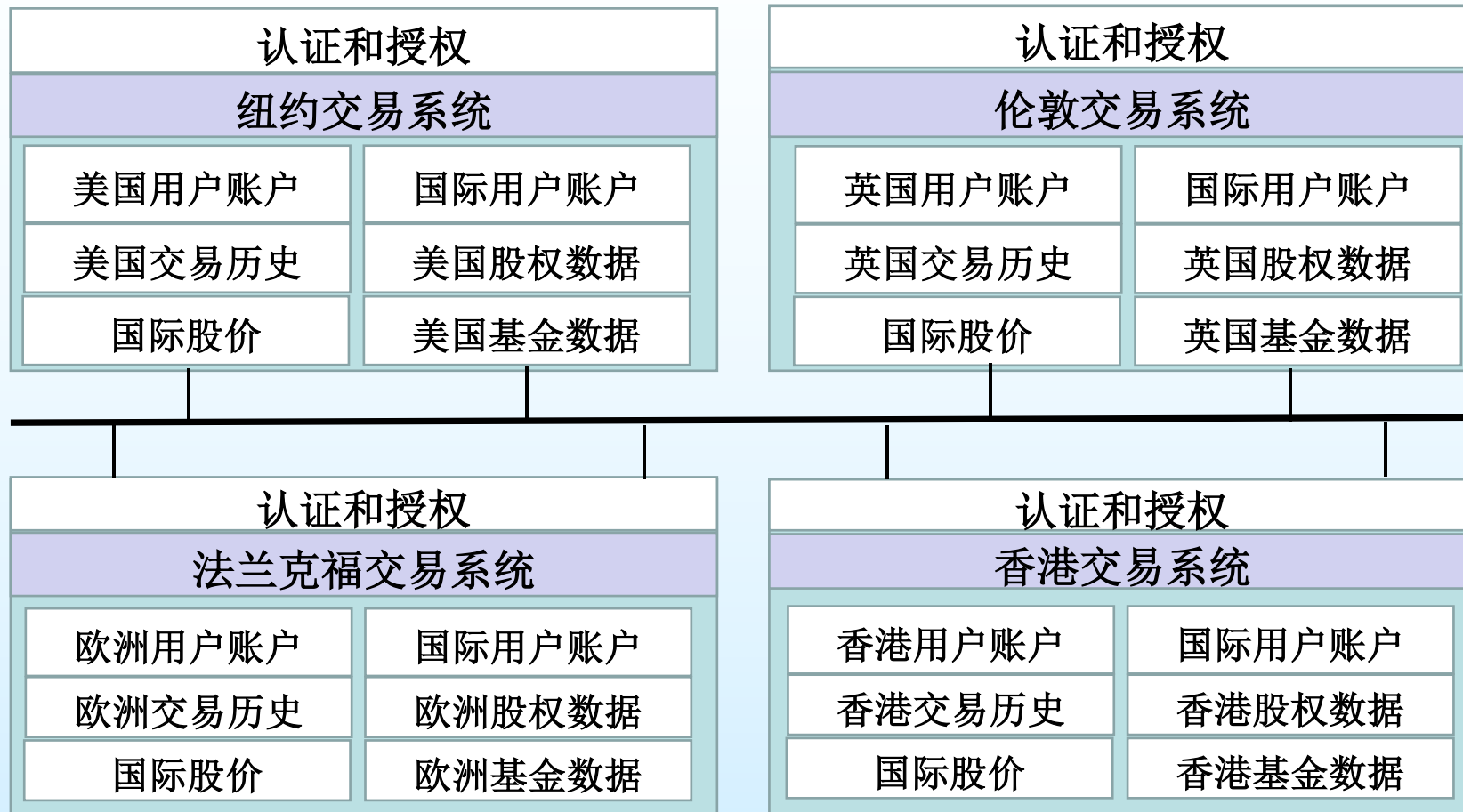


医疗就诊系统的分层保护体系结构

四、信息安全工程

3. 信息安全体系结构

如果服务器漏洞后果很严重，可采用分布式体系结构。



谢谢观看

